WEB APPLICATION

VAPT REPORT

Project 2 - OWASP Juice Shop

Assessment type	Authenticated and unauthenticated web application VAPT
Target	OWASP Juice Shop at 127.0.0.1:3000
Environment	Kali Linux VM with Docker-hosted Juice Shop
Tools	Nmap, WhatWeb, Nikto, cURL, Burp Suite Professional
Assessment date	01 October 2026
Scope constraint	Loopback lab target only; intentionally vulnerable application

AUTHORIZED LAB NOTICE

All testing documented in this report was performed against the intentionally vulnerable OWASP Juice Shop application running on the local loopback interface (127.0.0.1). No third-party or production systems were intentionally targeted.

Prepared for cybersecurity portfolio use

1. Executive Summary

This assessment evaluated an intentionally vulnerable OWASP Juice Shop deployment hosted locally on 127.0.0.1:3000. Testing combined reconnaissance, manual web testing, controlled exploitation, and Burp Suite Professional passive/active analysis.

Six meaningful security findings were documented: one critical SQL injection authentication bypass, one high-impact broken object level authorization/IDOR, two medium findings (client-side XSS and sensitive file exposure), and two lower-impact configuration/information disclosure findings (verbose errors and permissive CORS). Severity is an internal assessment based on the demonstrated impact in this lab and is not a CVSS score.

ID	Finding	Severity	Primary OWASP 2025 category
VULN-01	SQL Injection / Authentication Bypass	Critical	A05 Injection
VULN-02	IDOR / Broken Object Level Authorization	High	A01 Broken Access Control
VULN-03	Client-side XSS	Medium	A05 Injection
VULN-04	Sensitive File Exposure via /ftp	Medium	A01 Broken Access Control
VULN-05	Verbose Error / Stack Trace Disclosure	Low-Medium	A10 Mishandling of Exceptional Conditions
VULN-06	Permissive CORS / Arbitrary Origin Trusted	Low-Medium	A02 Security Misconfiguration

Overall assessment

The strongest demonstrated attack paths are authentication bypass through SQL injection and unauthorized cross-user object access through the user API. Client-side XSS provides browser-side code execution, while file exposure, verbose errors, and permissive CORS increase the attack surface and reconnaissance value.

2. Scope and Rules of Engagement

In-scope target: http://127.0.0.1:3000 and the OWASP Juice Shop instance exposed by the local Docker container.

Authorization: Testing was limited to the user-controlled lab environment and the deliberately vulnerable Juice Shop target.

Out-of-scope: External domains, third-party services, production systems, and any non-loopback targets were not intentionally tested.

Testing approach: Reconnaissance followed by controlled manual validation. Findings were retained only when behavior could be demonstrated or was clearly identified by Burp against the scoped target.

Data handling: No real user data was intentionally targeted. A dedicated synthetic customer account was created to validate the IDOR scenario.

3. Lab Architecture

The lab was designed to keep the vulnerable target isolated and repeatable. Kali Linux acted as the assessment workstation; Docker hosted the Juice Shop application; Burp Suite intercepted HTTP traffic for request inspection and scanning.

Layer	Component	Role
Analyst	Kali Linux	Recon, cURL, Nmap, WhatWeb, Nikto, Burp Suite Professional
Proxy	Burp Suite Professional	HTTP interception, Repeater, crawl/audit, issue detection
Target	Docker: OWASP Juice Shop	Intentionally vulnerable web application at 127.0.0.1:3000

4. Methodology and Tooling

1. **Reconnaissance:** Nmap service detection, WhatWeb application fingerprinting, robots.txt review, and endpoint discovery.
2. **Web enumeration:** Nikto and manual requests to interesting paths such as /ftp and error-handling endpoints.
3. **Manual exploitation:** Controlled tests for SQL injection, client-side XSS, and broken object level authorization.
4. **Intercepted testing:** Firefox was configured to use Burp on 127.0.0.1:8080. Juice Shop was added to scope and Burp Crawl and Audit was run with a Balanced configuration.
5. **Evidence validation:** Findings were retained only when the response, application behavior, or Burp issue data provided direct support. IDOR was validated using a synthetic customer account.
6. **Reporting:** Findings were mapped to the OWASP Top 10:2025 taxonomy with practical severity and remediation guidance.

Tool	Observed version	Use in assessment
Nmap	7.99	Service/port enumeration
WhatWeb	Observed from Kali package	Technology fingerprinting
Nikto	2.6.1	Web server checks
cURL	8.21.0 (observed via Burp request)	Manual HTTP/API requests
Burp Suite Professional	2026.3.3	Proxy, Repeater, Crawl and Audit

5. Reconnaissance Results

Nmap identified TCP/3000 as open on the loopback target. WhatWeb identified the application title as OWASP Juice Shop and confirmed a JavaScript-based web application. robots.txt exposed /ftp, which was subsequently validated as accessible.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p 3000 127.0.0.1
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-01 10:42 +0530
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00036s latency).

PORT     STATE SERVICE VERSION
3000/tcp open  ppp?
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/c
ce :
SF-Port3000-TCP:V=7.99%I=7%D=10/1%Time=6ABDEBCA%P=aarch64-unknown-linux-gn
SF:u%r(GetRequest,2668,"HTTP/1\.1\x20200\x20OK\r\nAccess-Control-Allow-Ori
SF:gin:\x20\*\r\nX-Content-Type-Options:\x20nosniff\r\nX-Frame-Options:\x2
SF:0SAMEORIGIN\r\nFeature-Policy:\x20payment\x20'self'\r\nX-Recruiting:\x2
SF:0/#/jobs\r\nAccept-Ranges:\x20bytes\r\nCache-Control:\x20public,\x20max
SF:-age=0\r\nLast-Modified:\x20Thu,\x2001\x20Oct\x202026\x2005:08:01\x20GM
SF:T\r\nETag:\x20W/\"24b1-1a0f5dcc4a5\"\r\nContent-Type:\x20text/html;\x20
SF:charset=UTF-8\r\nContent-Length:\x209393\r\nVary:\x20Accept-Encoding\r\
SF:nDate:\x20Thu,\x2001\x20Oct\x202026\x2005:12:42\x20GMT\r\nConnection:\x
SF:20close\r\n\r\n<!--\n\x20\x20~\x20Copyright\x20\(c\)\x202014-2026\x20Bj
SF:oern\x20Kimminich\x206\x20the\x20OWASP\x20Juice\x20Shop\x20contributors
SF:\.\n\x20\x20~\x20SPDX-License-Identifier:\x20MIT\n\x20\x20-->\n\n<!doct
SF:ype\x20html>\n<html\x20lang=\"en\"\x20data-beasties-container>\n<head>\
SF:n\x20\x20<meta\x20charset=\"utf-8\">\n\x20\x20<title>OWASP\x20Juice\x20
SF:Shop</title>\n\x20\x20<meta\x20name=\"description\"\x20content=\"Probab
SF:ly\x20the\x20most\x20modern\x20and\x20sophisticated\x20insecure\x20web\
SF:x20application\">\n\x20\x20<meta\x20name=\"viewport\"\x20content=\"widt
SF:h=device-width,\x20initial-scale=1\">\n\x20\x20<link\x20rel=\"preconnec
SF:t\"\x20href=\"htt")%r(Help,2F,"HTTP/1\.1\x20400\x20Bad\x20Request\r\nCo
SF:nnection:\x20close\r\n\r\n")%r(NCP,2F,"HTTP/1\.1\x20400\x20Bad\x20Reque
SF:st\r\nConnection:\x20close\r\n\r\n")%r(HTTPOptions,EA,"HTTP/1\.1\x20204
SF:\x20No\x20Content\r\nAccess-Control-Allow-Origin:\x20\*\r\nAccess-Contr
SF:ol-Allow-Methods:\x20GET,HEAD,PUT,PATCH,POST,DELETE\r\nVary:\x20Access-
SF:Control-Request-Headers\r\nContent-Length:\x200\r\nDate:\x20Thu,\x2001\
SF:x20Oct\x202026\x2005:12:42\x20GMT\r\nConnection:\x20close\r\n\r\n")%r(R
SF:TSPRequest,EA,"HTTP/1\.1\x20204\x20No\x20Content\r\nAccess-Control-Allo
SF:w-Origin:\x20\*\r\nAccess-Control-Allow-Methods:\x20GET,HEAD,PUT,PATCH,
SF:POST,DELETE\r\nVary:\x20Access-Control-Request-Headers\r\nContent-Lengt
SF:h:\x200\r\nDate:\x20Thu,\x2001\x20Oct\x202026\x2005:12:42\x20GMT\r\nCon
SF:nection:\x20close\r\n\r\n");

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.44 seconds
```

Figure 1. Nmap service detection against 127.0.0.1:3000.

```
    });
  </script>
 </head>
 <body class="directory">
   <input id="search" type="text" placeholder="Search" autocomplete="off" />
   <div id="wrapper">
     <h1><a href="/">~</a> / <a href="ftp">ftp</a></h1>
     <ul id="files" class="view-tiles"><li><a href="ftp/quarantine" class="icon icon-directory" title="quarantine"><span class="name">quarantine</span><span class=
"></span><span class="date">8/11/2026 5:21:02 AM</span></a></li>
li><a href="ftp/acquisitions.md" class="icon icon icon-md icon-text" title="acquisitions.md"><span class="name">acquisitions.md</span><span class="size">909</span>
 class="date">8/11/2026 5:21:02 AM</span></a></li>
li><a href="ftp/announcement_encrypted.md" class="icon icon icon-md icon-text" title="announcement_encrypted.md"><span class="name">announcement_encrypted.md</span
n class="size">369237</span><span class="date">8/11/2026 5:21:02 AM</span></a></li>
li><a href="ftp/coupons_2013.md.bak" class="icon icon icon-bak icon-default" title="coupons_2013.md.bak"><span class="name">coupons_2013.md.bak</span><span class="
>131</span><span class="date">8/11/2026 5:21:02 AM</span></a></li>
li><a href="ftp/eastere.gg" class="icon icon icon-gg icon-default" title="eastere.gg"><span class="name">eastere.gg</span><span class="size">324</span><span class=
">8/11/2026 5:21:02 AM</span></a></li>
li><a href="ftp/encrypt.pyc" class="icon icon icon-pyc icon-default" title="encrypt.pyc"><span class="name">encrypt.pyc</span><span class="size">573</span><span cl
date">8/11/2026 5:21:02 AM</span></a></li>
li><a href="ftp/incident-support.kdbx" class="icon icon icon-kdbx icon-default" title="incident-support.kdbx"><span class="name">incident-support.kdbx</span><span
="size">3246</span><span class="date">8/11/2026 5:21:02 AM</span></a></li>
li><a href="ftp/legal.md" class="icon icon icon-md icon-text" title="legal.md"><span class="name">legal.md</span><span class="size">3047</span><span class="date">1
026 5:07:59 AM</span></a></li>
li><a href="ftp/package-lock.json.bak" class="icon icon icon-bak icon-default" title="package-lock.json.bak"><span class="name">package-lock.json.bak</span><span c
"size">750353</span><span class="date">8/11/2026 5:21:02 AM</span></a></li>
li><a href="ftp/package.json.bak" class="icon icon icon-bak icon-default" title="package.json.bak"><span class="name">package.json.bak</span><span class="size">426
an><span class="date">8/11/2026 5:21:02 AM</span></a></li>
li><a href="ftp/suspicious_errors.yml" class="icon icon icon-yml icon-text" title="suspicious_errors.yml"><span class="name">suspicious_errors.yml</span><span clas
```

Figure 2. Exposed /ftp directory listing returned by the Juice Shop application.

6. Detailed Findings

VULN-01 - SQL Injection / Authentication Bypass

Severity **Critical**	**OWASP 2025** **A05 Injection; authentication impact under A07 Authentication Failures**	**Status** **Confirmed**	**Confidence** **High / Direct evidence**

Affected endpoint: POST /rest/user/login

Evidence: The crafted email value ' OR 1=1-- caused the login API to return HTTP 200 and an authentication token associated with the Juice Shop administrator account. The same payload was also entered through the application login page and successfully redirected into the authenticated application.

Impact: An attacker who can reach the login endpoint may bypass authentication and obtain administrative access, potentially allowing access to privileged functionality and data.

Root cause: The behavior is consistent with attacker-controlled input being incorporated into an authentication query without safe parameterization.

Remediation: Use parameterized/prepared statements or ORM query APIs that keep data separate from SQL syntax. Remove string concatenation from authentication queries, add server-side validation, and add negative security tests for authentication inputs.

Retest: Repeat the same payload after remediation and verify that authentication fails and no privileged token is issued.

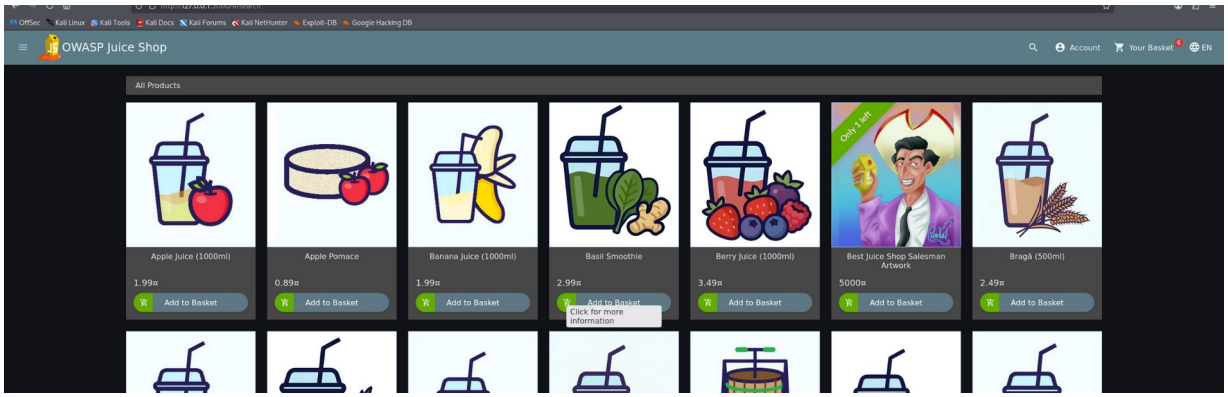


Figure 3. Browser evidence showing successful authentication into the Juice Shop after the SQL injection test.

VULN-02 - IDOR / Broken Object Level Authorization

Severity High	OWASP 2025 A01 Broken Access Control	Status Confirmed	Confidence High / Direct evidence

Affected endpoint: GET /api/Users/{id}

Evidence: A dedicated synthetic customer account was created as user ID 25. Using the customer authentication token, GET /api/Users/1 returned the administrator record (id 1, admin@juice-sh.op, role admin). Only the object identifier changed between the customer self-access check and the unauthorized administrator-object request.

Impact: A low-privileged authenticated user can read another user's object, including the administrator record. The same class of missing object-level authorization can expose broader user data if repeated across other endpoints.

Root cause: The API authenticates the caller but does not sufficiently authorize access to the requested object identifier.

Remediation: Perform server-side authorization checks for every object access. Verify that the authenticated principal is allowed to access the requested user/object. Do not rely on numeric IDs being secret or difficult to guess.

Retest: Authenticate as a normal customer and request another user's object. The server should return HTTP 403 or an equivalent authorization failure without disclosing the object.



Figure 4. Direct API evidence: customer token used to request administrator user object ID 1 and receive the admin record.

VULN-03 - Client-side Cross-Site Scripting (XSS)

Severity	OWASP 2025	Status	Confidence
Medium	A05 Injection	Confirmed	High / Direct evidence

Affected area: Search route: /#/search with attacker-controlled query string.

Evidence: A crafted search URL caused the application browser to execute JavaScript and display an alert containing the text "xss". This is direct visual evidence of script execution in the client context.

Impact: Depending on the application context, client-side script execution can alter page content, access browser-accessible application state, or perform actions on behalf of the victim.

Root cause: User-controlled search input reaches a browser execution context without adequate context-aware encoding or safe DOM handling.

Remediation: Use framework-safe templating, context-aware output encoding, avoid unsafe DOM sinks, sanitize HTML only where HTML is required, and deploy a restrictive Content Security Policy as defense in depth.

Retest: Repeat the same search with the test payload and verify that it is rendered as data and no JavaScript executes.

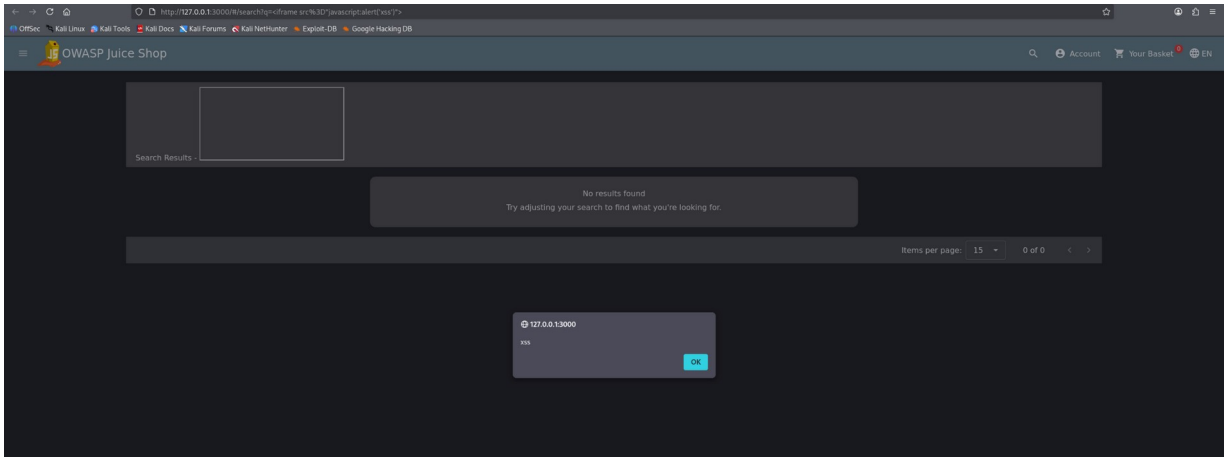


Figure 5. Browser evidence of JavaScript execution from the crafted search URL.

VULN-04 - Sensitive File Exposure via /ftp

Severity Medium	OWASP 2025 A01 Broken Access Control	Status Confirmed	Confidence High / Direct evidence

Affected path: /ftp/

Evidence: robots.txt exposed /ftp. Direct requests to /ftp returned a directory listing including acquisitions.md, legal.md, and other internal-looking files. acquisitions.md and legal.md were retrieved successfully.

Impact: Web-accessible internal documents may disclose confidential or operational information and assist further attacks.

Root cause: Sensitive documents are stored beneath a web-accessible path without sufficient access restrictions.

Remediation: Move sensitive documents outside web roots, disable directory listing, enforce authorization before serving files, and deny direct access to internal storage locations.

VULN-05 - Verbose Error / Stack Trace Disclosure

Severity Low-Medium	OWASP 2025 A10 Mishandling of Exceptional Conditions	Status Confirmed	Confidence High / Direct evidence

Affected behavior: Invalid requests to the file endpoint returned detailed Express/Node.js error information.

Evidence: The response exposed framework/version information and internal paths such as /juice-shop/node_modules/express/... in the HTML error page.

Impact: Detailed implementation information can help attackers fingerprint the application and identify useful routes, libraries, and error paths.

Root cause: Production-style error handling is exposing diagnostic details to clients instead of returning a generic error response.

Remediation: Return generic client-facing errors, keep stack traces in server-side logs, disable debug output in production, and centralize exception handling.

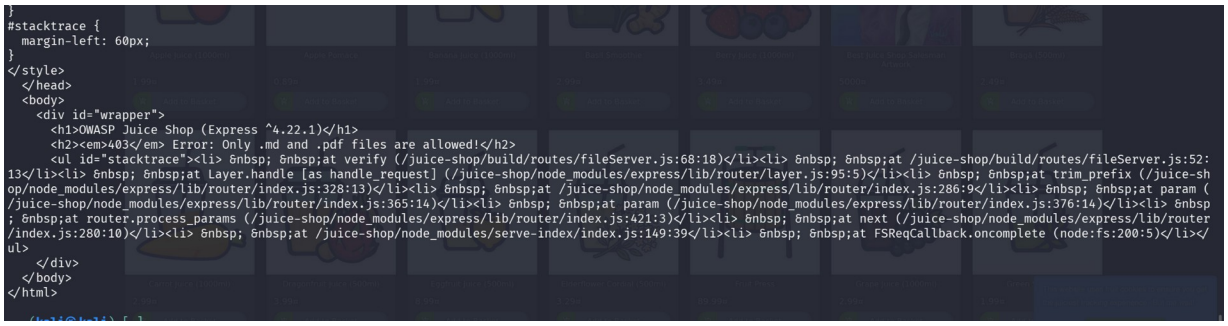


Figure 6. Error response exposing Express/Node.js stack information.

VULN-06 - Permissive CORS / Arbitrary Origin Trusted

Severity Low-Medium	OWASP 2025 A02 Security Misconfiguration	Status Burp-identified	Confidence Certain (scanner)

Affected behavior: Burp identified "Cross-origin resource sharing: arbitrary origin trusted" across multiple Juice Shop resources.

Evidence: The scoped Burp Crawl and Audit reported the issue with certain confidence on the local Juice Shop host. The issue appears on resources including /main.js, /scripts.js, /styles.css, /ftp/*, and /robots.txt.

Impact: Permissive origin trust can expand the set of origins that can interact with application resources cross-origin. The impact depends on what sensitive resources are accessible with browser credentials.

Root cause: CORS policy is broader than required for a secure deployment.

Remediation: Use an explicit allowlist of trusted origins, avoid wildcard origins where credentials or sensitive data are involved, and restrict methods and headers to what the application requires.

Retest: Send requests with an untrusted Origin header and verify that the server does not grant cross-origin access to protected resources.

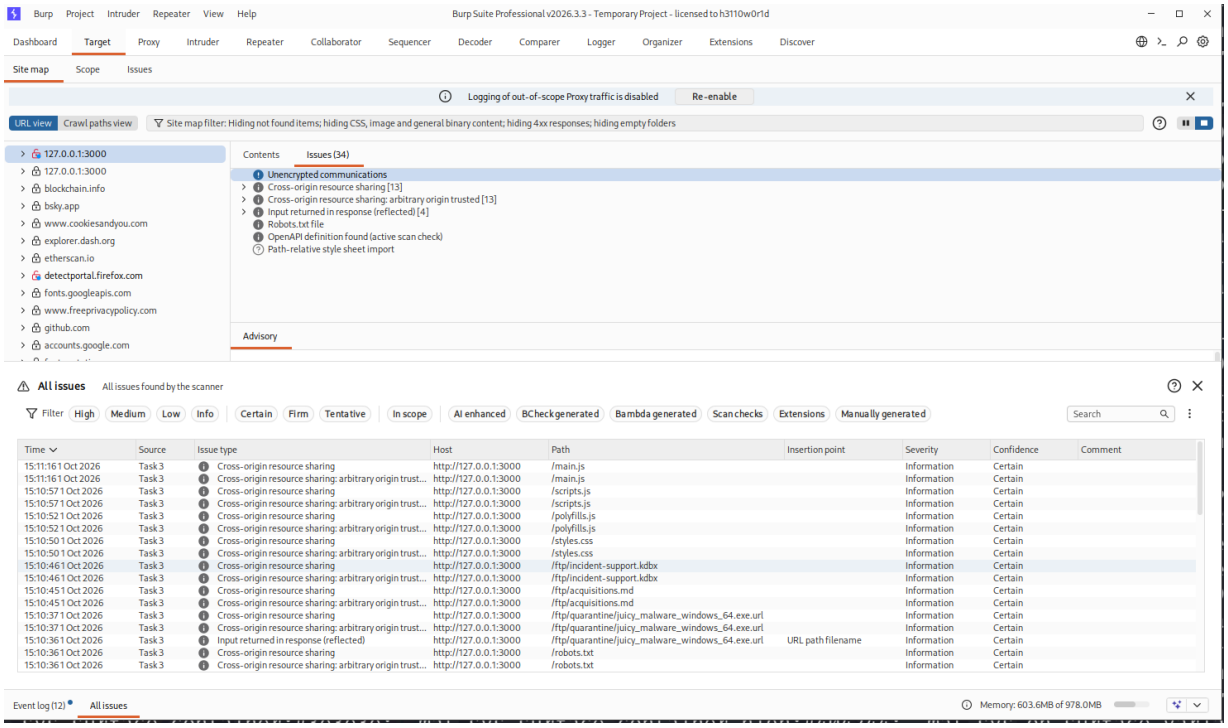


Figure 7. Burp Suite scoped scan results showing CORS-related findings and exposed /ftp resources.

7. Risk Summary and Remediation Priorities

The table below is the reporting priority used for this lab. It reflects demonstrated exploitability and impact, not a formal CVSS calculation.

Priority	Finding	Primary impact	Recommended action
P1	VULN-01 - SQLi/Auth Bypass	Administrative authentication bypass	Parameterize SQL; remove injectable query construction; add auth security tests.
P1	VULN-02 - IDOR/BOLA	Cross-user data access	Enforce per-object authorization on every API read/write.
P2	VULN-03 - XSS	Browser-side script execution	Safe templating/DOM APIs, encoding, sanitization where needed, CSP.
P2	VULN-04 - File exposure	Disclosure of internal documents	Remove from web root; require authorization; disable directory browsing.
P3	VULN-05 - Error disclosure	Implementation fingerprinting	Generic client errors; detailed logs only server-side.
P3	VULN-06 - CORS	Over-broad cross-origin trust	Allowlist trusted origins and limit methods/headers.

8. Retest Plan

- **SQL injection:** Submit the same login payload. Expected: authentication fails; no privileged token is returned.
- **IDOR/BOLA:** Authenticate as the test customer and request /api/Users/1. Expected: authorization failure; no admin record returned.
- **XSS:** Reload the crafted search route. Expected: payload is rendered inert or encoded; no JavaScript execution.
- **File exposure:** Request /ftp and known filenames. Expected: no directory listing and no unauthorized file content.

- **Error handling:** Repeat invalid requests. Expected: generic error with no stack trace, framework versions, or internal file paths.
- **CORS:** Send untrusted Origin requests. Expected: no permissive cross-origin authorization for protected resources.

9. Limitations

- The assessment targeted a deliberately vulnerable educational application; its behavior is not representative of a hardened production system.
- Testing was confined to the local loopback host and did not assess network segmentation, infrastructure controls, source code, CI/CD, cloud configuration, or external dependencies.
- Burp scanner findings were treated as supporting evidence; duplicate and informational items were not automatically promoted to report findings.
- No persistence, destructive actions, data deletion, malware execution, or testing of unrelated external systems was performed.

10. Conclusion

The Project 2 lab successfully demonstrated a repeatable web application VAPT workflow using Kali Linux, Docker, command-line reconnaissance tools, and Burp Suite Professional. The exercise produced six defensible findings across authentication, injection, access control, client-side security, information disclosure, and security configuration. The strongest evidence comes from the successful SQL injection authentication bypass and the customer-to-administrator object access test, both validated directly against the local target.

Portfolio positioning

This project demonstrates hands-on capability in web application reconnaissance, API testing, authentication testing, Burp Suite workflow, controlled exploitation, evidence collection, vulnerability classification, and remediation planning.

11. References

- OWASP Top 10:2025: https://top10.owasp.org/2025/
- OWASP A01:2025 - Broken Access Control: https://top10.owasp.org/2025/A01_2025-Broken_Access_Control/
- OWASP A02:2025 - Security Misconfiguration: https://top10.owasp.org/2025/A02_2025-Security_Misconfiguration/
- OWASP A05:2025 - Injection: https://top10.owasp.org/2025/A05_2025-Injection/
- OWASP A07:2025 - Authentication Failures: https://top10.owasp.org/2025/A07_2025-Authentication_Failures/
- OWASP A10:2025 - Mishandling of Exceptional Conditions: https://top10.owasp.org/2025/A10_2025-Mishandling_of_Exceptional_Conditions/
- CWE-79 - Improper Neutralization of Input During Web Page Generation: https://cwe.mitre.org/data/definitions/79.html

- CWE-209 - Generation of Error Message Containing Sensitive Information: https://cwe.mitre.org/data/definitions/209.html
- CWE-942 - Permissive Cross-domain Policy with Untrusted Domains: https://cwe.mitre.org/data/definitions/942.html
- PortSwigger Web Security Academy: https://portswigger.net/web-security

Appendix A - Key Commands Used

Nmap:

```
nmap -sV -p 3000 127.0.0.1
```

WhatWeb:

```
whatweb http://127.0.0.1:3000
```

robots.txt:

```
curl -s http://127.0.0.1:3000/robots.txt
```

FTP listing:

```
curl -s http://127.0.0.1:3000/ftp
```

Sensitive file:

```
curl -s http://127.0.0.1:3000/ftp/acquisitions.md
```

Nikto:

```
nikto -h http://127.0.0.1:3000
```

SQLi login test:

```
POST /rest/user/login with email value: ' OR 1=1--
```

XSS test:

```
/#/search?q=<iframe src="javascript:alert('xss')">
```

IDOR test:

```
GET /api/Users/1 using a normal customer token (test account ID 25)
```